
Unidad VI

La Administración de Recursos de SI/TI - Seguridad y Auditoría de Sistemas de Información

Los **procesos de control del ambiente informático** son las herramientas que garantizan que las tecnologías y áreas relacionadas al procesamiento de la información funcionen **adecuadamente**. Cualquier punto en donde se tiene un procesamiento de información, aunque sea en papel tiene que cumplir con las pautas de estos procesos de control.

Los procesos de control son:

- **Gestión de la seguridad de los SI/TI**
- **Auditoría de los SI/TI**

Management responsable de IS

La gestión o management de la seguridad del ambiente informático consiste en la administración de los SI/TI de un “modo seguro”.

Cuando nos referimos a los IS seguros nos referimos a los siguientes aspectos:

1. **“seguros” desde un punto de vista organizacional, es decir, técnico.**
 - Aquí se usan las herramientas. Las fuentes de datos (formularios) y procedimientos internos están en este aspecto
2. **“seguros” desde un punto de vista social, es decir, ético**
3. **“seguros” desde un punto de vista judicial, es decir, legal**
 - ¿Como son los requisitos legales para ciertos procedimientos? Es un ejemplo de este aspecto

El entorno organizacional se debe pensar y diseñar para que todo siga siendo seguro.

Estos tres puntos -el ético, el legal y el que hace a la seguridad- se superponen. Es frecuente que existan obligaciones legales y morales en relación con la seguridad de la información y su almacenamiento, procesamiento y recuperación. El marco legislativo actual de los SI codifica una perspectiva social de lo que es correcto, es decir, de la ética. Mantener la seguridad de los SI puede plantear dilemas legales y éticos.

Manejo de la seguridad de los IS

Se procederá al análisis desde el punto de vista técnico.

Este aspecto se refiere a la visualización y el management de los riesgos en términos de las causas, los efectos y, por tanto, los costos que implica una **pérdida de seguridad**. Ésta puede definirse como: *"la falla de los elementos de un sistema de información computarizado para realizar la función o brindar el o los servicios para los cuales estaba destinado"*.

Dicha falla puede referirse a la pérdida de uno de los siguientes aspectos (o de todos). La gestión de la seguridad significa gestionar estos aspectos:

- **Integridad de la información:** La pérdida de seguridad destruye la capacidad de una empresa para confiar en sus datos, o peor, de contar con datos de precisión incierta.
- **Operatividad/disponibilidad:** La pérdida de la seguridad destruye, total o parcialmente, la habilidad de la empresa para acceder a datos e información.
- **Confidencialidad:** la pérdida de seguridad destruye la posesión exclusiva de datos, lo que provoca que la organización pierda poder y confianza. También involucra acceder a la info que al rol le corresponde desde sus responsabilidades organizacionales

La pérdida de un aspecto puede impactar en otros aspectos

De esta definición se desprende la noción de que las organizaciones necesitan administrar el riesgo de exposición de cada uno de los elementos de los IS. Este management deberá considerar el equilibrio entre los costos resultantes de una falla de seguridad y los costos resultantes de las medidas necesarias para aumentar la seguridad. El punto central es identificar el equilibrio óptimo.

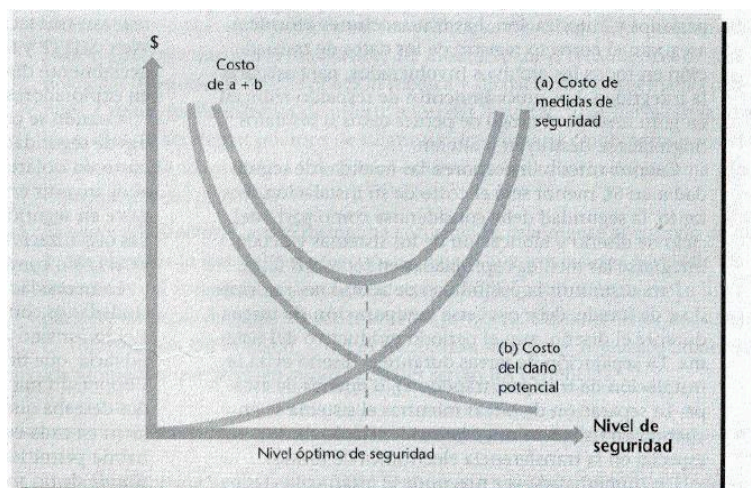


Figura 17.14 El costo total para la empresa es más bajo en el punto "óptimo". No debe gastarse ni menos ni más en medidas de seguridad de información

El costo de no tener seguridad puede ser difícil de definir, aun cuando las fallas ocurran. **El management del riesgo intenta reducir estas pérdidas.** Un enfoque sistemático del management del riesgo permitirá que los IS de seguridad sean administrados de forma tal que reconozcan la vulnerabilidad y la sensibilidad de los sistemas de la empresa, y los datos que estos contienen, pero también los costos de los controles y las medidas para el

manejo de riesgos. Ningún sistema puede ser completamente seguro. **El management permite elegir e implementar las contramedidas de una forma planeada y administrada.**

No se administra la seguridad en sí sino el nivel de riesgo. Menos nivel de riesgo tengo, más seguridad tengo. Se ven y evalúan medidas sobre el riesgo.

Premisas

- La seguridad total es imposible. Solo se logra un nivel razonable.
- Mejor manejo de riesgo. El management busca el equilibrio entre los costos resultantes de una falla y los costos resultantes de las medidas necesarias para aumentar la seguridad.

El management de seguridad de SI se reduce a **4 etapas:**

- Identificación del riesgo
- Análisis del riesgo
- Manejo del riesgo
- Recuperación ante el desastre

Identificación del riesgo

El primer paso es **identificar “todos” los riesgos a los que es vulnerable un sistema particular, un conjunto de sistemas, una función o una empresa.** Para realizar esta tarea, se necesitan dos cosas: un *conocimiento bastante detallado del trabajo de la organización*, más un *reconocimiento de las áreas que tienden a la vulnerabilidad*. Esta segunda parte, es decir, la comprensión del riesgo probable puede llevarse a cabo a través de consultores externos, pero la identificación de las amenazas específicas se realiza probablemente mejor mediante el personal o los consultores internos. Los consultores externos ofrecen un amplio conocimiento, mientras que el personal interno ofrece una profunda comprensión de la empresa.

Se trata de encontrar los puntos débiles, es decir todo aquello a lo que está potencialmente expuesto el ambiente informático. Se debe identificar:

- Fuentes de amenazas potenciales,
- Activos vulnerables a la pérdida,
- Ubicación de los riesgos.

El orden es el siguiente:

- Activos
- Vulnerabilidades de los activos
- Amenazas

Definiciones

Amenaza: condición del entorno del sistema de información (persona, máquina, suceso o idea) que, dada una oportunidad, podría dar lugar a que se produjese una violación de

seguridad (confidencialidad, integridad, disponibilidad, autenticidad, no repudio). **Es algo con capacidad de daño.** Un ataque es la realización de una amenaza.

Las amenazas pueden afectar a la disponibilidad (interrupción), la integridad (modificación), o la confidencialidad (intercepción).

Existen distintos tipos de amenazas:

- Física o lógicas,
- Accidental o deliberada.

La vulnerabilidad de un área en particular es dependiente de los siguientes factores:

- El personal de la organización.
- El tamaño de la red.
- La calidad de la transmisión de datos.



Intento de amenaza	Elemento amenazado	
	Físico	Lógico
Accidental	Ej: Fallas en los equipos Fallas de energía Relámpagos Inundación Incendio	Ej: Error del usuario Error de programación (bugs) Error en la configuración
Deliberada	Ej: Robo Sabotaje	Ej: Virus Piratería Fraude Hacking

Figura 13.3. Lista de identificación de amenazas.

Los **activos vulnerables** a pérdidas debido a una amenaza pueden ser:

- **Hardware:** pérdida relativamente fácil de evaluar y estos elementos están a menudo asegurados.
- **Software:** la principal complicación cuando se evalúa la pérdida de software es que el valor intrínseco o costo de reemplazo, del software no tiene relación con el costo original de desarrollo. Para sumar complicaciones, la pérdida de software genera una pérdida de la capacidad de procesamiento y, entonces, el factor debe incluirse en la cuantificación de pérdida del software.
- **Datos e información:** es la pérdida más seria y la más difícil de cuantificar.
- **Capacidad de procesamiento:** la duración de la interrupción es la variable clave al

determinar el valor de la pérdida. Por ejemplo, que por accesos no autorizados me usen mi servidor y yo no puedo usar.

- **Personal:** esta pérdida puede ser significativa ya sea por su conocimiento teórico o por su competencia práctica.
- **Fondos.**

Riesgo: es el potencial de que una amenaza determinada explote las vulnerabilidades de un activo o de un grupo de activos, ocasionando su pérdida o daño (ISACA).

El concepto de **riesgo** está relacionado con el de materialidad, que se refieren a la magnitud del error en términos del impacto potencial para el conjunto de la organización. En general esa materialidad es expresada en términos monetarios.

Elementos del riesgo:

- **Activos:** información, datos, HW, SW, servicios, documentos, personal, etc.
- **Amenazas:** son el resultado de un análisis de vulnerabilidades: errores, ataque malicioso, fraude, robo, fallas de equipos, fallas de SW.
- **Vulnerabilidades:** lo que es atacable: falta de conocimientos del usuario, falta de funcionalidad de la seguridad, mala elección de las contraseñas, tecnología no probada, transmisiones no seguras, etc. **Por donde entra la amenaza,** por donde ataca a mi activo.
- **Impactos:** son las pérdidas consecuentes de la ocurrencia de una amenaza: pérdida directa de dinero, violación de las leyes, pérdida de reputación, violación de la confianza, pérdida de oportunidad de negocio, reducción de la eficiencia, interrupción de las actividades del negocio.
- **Riesgo Global:** Una vez que los elementos del riesgo se establecen, se combinan para formar el carácter global del riesgo. (cálculo del impacto de probabilidad para cada amenaza).
- **Riesgo Residual:** es el nivel de riesgo restante una vez que se han aplicado los controles. Puede ser utilizado por la gerencia para identificar las áreas en que se requiere más control para reducir aún más los riesgos, o bien para identificar puntos de control que estén siendo sobre controlados.

Análisis del riesgo

Ahora tengo que relacionar activos, vulnerabilidades, lugares que se producen para poder formularlo, expresarlo y calcularlo. Acá le pongo valor monetario al que si esto ocurre

Una vez detectadas las amenazas, se puede proceder con el análisis de su impacto potencial. Si la etapa de identificación constituye una forma de “pensamiento creativo y espontáneo”, entonces la etapa de análisis del riesgo es un proceso más estructurado, aunque a menudo de una manera cualitativa y no cuantitativa. **Consiste en analizar el impacto potencial, para determinar la pérdida esperada producida por una amenaza particular.** El análisis debe evaluar la pérdida esperada, producida por una amenaza el particular, en donde:

$$\text{Pérdida esperada} = \text{Pérdida potencial (\$)} \cdot \text{Frecuencia de pérdida}$$

Donde

$$\text{Frecuencia de pérdida} = \text{probabilidad agresión} \cdot \text{probabilidad de éxito}$$

Esto se hace por cada activo o grupo de activos que se identificó en la primera etapa

El análisis del impacto potencial requiere de **dos etapas**. La primera *evalúa los costos empresariales que surgen de una brecha en la seguridad*. Esta evaluación debería incluir, al menos, de un modo aproximado, cálculos financieros incluso para los costos conceptuales. Existe un gran número de aspectos relacionados con las pérdidas potenciales provenientes de una falla de seguridad.

A esto se le suma la posibilidad calculada de que suceda y entonces *la segunda etapa del análisis de riesgo consiste en estimar la frecuencia de ocurrencia* de cualquier falla de seguridad a través de la probabilidad de agresión *y la probabilidad de que la agresión prospere* (se entiende por agresión a cualquier falla en la seguridad, no necesariamente a un deliberado abuso humano).

Amenaza	Probabilidad de agresión		x Probabilidad de éxito		= Frecuencia
Entrada de datos incorrecta	muy alta	90%	mediana	50%	45%
Incendio	mediana	50%	alta	70%	35%
Hacking	baja	20%	mediana	50%	10%

Nota: la reducción del riesgo discutida en la Sección 13.1.3 puede disminuir la probabilidad de agresión o la probabilidad de éxito a fin de reducir la frecuencia; puede también reducir los costos resultantes para disminuir la pérdida general.

Figura 13.6. Cálculos de frecuencia de amenazas.

El producto de costo y frecuencia da como resultado la pérdida anual esperada para cada amenaza:

$$\text{Costo (de las consecuencias)} \times \text{Frecuencia (de los cálculos)} = \text{Exposición anual de pérdidas}$$

El análisis del riesgo establece un lado del punto de equilibrio óptimo entre el costo de pérdidas y el costo de medidas de seguridad. El manejo del riesgo identifica contra medidas posibles y luego elige el conjunto adecuado para ese trueque óptimo.

Un análisis de riesgo efectivo requiere una apreciación de la verdadera magnitud de las pérdidas resultantes de cada amenaza, lo cual es difícil de determinar. El management efectivo del riesgo también requiere una valoración realista de la posibilidad de que la amenaza se convierta en realidad.

Todas las pérdidas que resultan de una falla en la seguridad se relacionan con los atributos de valor agregado de la información y se las puede dividir en tres categorías:

1. **Pérdida de disponibilidad:** la pérdida de la seguridad destruye, total o parcialmente, la habilidad de la empresa para acceder a datos e información.

2. **Falla en la integridad/precisión:** la pérdida de seguridad destruye la capacidad de una empresa para confiar en sus datos, o peor, de contar con datos de precisión incierta.
3. **Pérdida de confidencialidad/seguridad:** la pérdida de seguridad destruye la posesión exclusiva de datos, lo que provoca que la organización pierda poder y confianza. Una vez más, el peor caso es el de incertidumbre.

Para evaluar la magnitud de la pérdida resultante de una falla en la seguridad es considerar las **consecuencias primarias**, es decir, **aquellas cosas que se desprenden directamente, y por lo general en forma inmediata, de un problema en la seguridad.** Ejemplo: pérdida del activo

Las **pérdidas secundarias (que surgen como consecuencia de las pérdidas primarias, y no de una falla en sí misma)** revisten gran importancia en los cálculos de pérdidas.

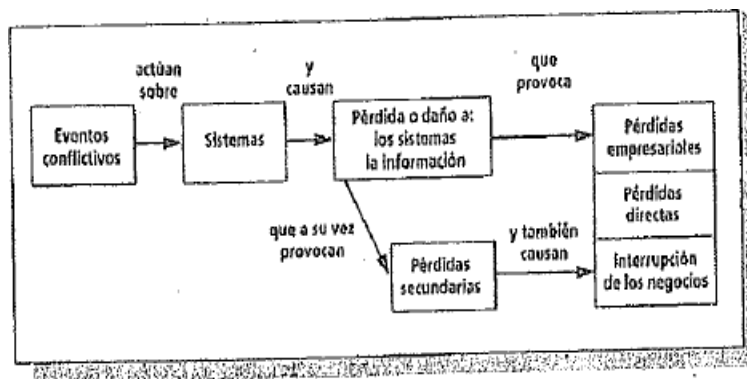


Figura 13.10. Pérdidas resultantes de una falla en la seguridad.

La magnitud de la pérdida total de una falla en la seguridad es la suma de las **consecuencias primarias y secundarias.** En el caso de que las consecuencias primarias puedan ser minimizadas, entonces habría una doble ganancia, porque si se reducen las pérdidas primarias, entonces las secundarias también se minimizan.

Ejemplos

Consecuencias Primarias	Consecuencias Secundarias
-------------------------	---------------------------

● Interrupción del procesamiento a corto o largo plazo. ● Corrupción de los registros de datos. ● Destrucción de los medios de almacenamiento. ● Uso de software no autorizado. ● Revelación de información confidencial. ● Desaparición de equipos, datos o software. ● Pérdida de los registros de contabilidad u otros.	● Pérdida en la producción. ● Retraso en las entregas. ● Problemas de flujo de efectivo. ● Pérdida de confianza del cliente. ● Declaraciones de impuesto imprecisas. ● Información gerencial inútil, imprecisa e inoportuna. ● Sanciones por incumplimiento de obligaciones legales. ● Incapacidad de continuar la función del sistema. ● Pérdida de una posición competitiva. ● Incapacidad de continuar con el negocio.
--	--

Manejo del Riesgo

La identificación y el análisis de las amenazas se realizan con el objetivo de implementar estrategias adecuadas que ofrezcan la mejor **efectividad** neta, es decir, que mantengan el equilibrio deseado. **Cualquier medida es más barata que perder los datos.**

El manejo del riesgo consiste en la aplicación de controles y contra medidas apropiadas para el riesgo, de acuerdo con el tiempo, el dinero y otras restricciones. Los pasos previos de:

1. Enumeración de amenazas potenciales.
2. Cuantificación de pérdidas que surgen como consecuencia de las amenazas exitosas.
3. Determinación de ALE (Tabla de pérdida anual) o alguna otra medida de probabilidad o gravedad de ocurrencia.

Constituyen un proceso valioso, pero sólo como un medio para alcanzar un fin. **El propósito es identificar el “mejor” método de manejo del riesgo, en donde “mejor” se define como un management de fallas potenciales de seguridad que sea efectivo en cuanto al costo.** Existen cuatro **estrategias genéricas para el manejo del riesgo**:

1. **Prevenir el riesgo:** son medidas para **intenta evitar la amenaza**. Por ej.: colocar los sistemas lejos de las áreas peligrosas, ubicar los datos delicados en áreas protegidas, no descentralizar, ANTIVIRUS. etc.
2. **Asumir el riesgo:** se utiliza cuando las pérdidas totales (suma de las consecuencias primarias y secundarias) son tolerables por la organización. Acá

también se debe tener en cuenta la probabilidad de ocurrencia

3. **Reducir el riesgo:** resulta difícil evitar por completo el riesgo y a veces es inadecuado ignorarlas. Consiste en la introducción de controles y contramedidas para **reducir la probabilidad de ocurrencia** y/o para **reducir las pérdidas resultantes** de una falla en la seguridad. Backup.

4. **Transferir el riesgo:** transfiere los costos resultantes de una falla en la seguridad a un tercero, que en general implica pólizas de seguros o contratos de mantenimiento. Efectivo para las amenazas de alto costo y baja probabilidad.

Identificar un portfolio de management de riesgo significa seleccionar un conjunto heterogéneo de estrategias de manejo del riesgo que dependen de la aplicación sistemática de la identificación y el análisis del riesgo.

Cada vez más, la seguridad de los SI debe ser considerada como un tema estratégico, y toda empresa debería invertir en seguridad. Si el resultado de las perdidas prevenidas o reducidas es mayor que el costo de seguridad, entonces existe una contribución neta a las ganancias.

Una **política de seguridad** define el nivel de seguridad que se ajusta al valor de lo que se debe proteger y al gasto e inconveniencia de las medidas de protección. Esas políticas documentan el resultado de la identificación y en análisis del riesgo, y de las estrategias elegidas para manejarlo. El documento debe cubrir al menos:

- La protección de la información.
- El valor de la información.
- El acceso a la información.
- La recuperación de la información.

Controles y contra medidas

Las estrategias de manejo del riesgo se implementan a través de controles y contra medidas. La elección del conjunto que, de un modo efectivo con respecto al costo, evita, reduce o transfiere el impacto del riesgo, **es obviamente un aspecto del management del riesgo**. Las medidas de seguridad y control deben ser consideradas en términos de los costos netos y de los nuevos riesgos potenciales resultantes de su adopción. Existen fundamentalmente dos tipos de control: **las contramedidas generales que se introducen para reducir la amenaza de todas las actividades de los SI dentro de una organización; y los controles de aplicación** diseñados para proteger de amenazas a un área específica.

Hasta cierto punto, los controles de aplicación son un conjunto de controles generales y para la mayoría de las empresas. Un punto débil en los controles generales podría provocar una pérdida de seguridad en cualquier sistema y así, el costo de estas medidas debería considerarse “compartido” por todas las áreas protegidas.

Controles: Prevención y detección, medidas implementadas antes de un incidente para reducir la probabilidad de que ocurra o para detectarlo tempranamente.

Contramedidas: Respuesta y mitigación, **medidas tomadas después de un incidente para limitar los daños** y recuperar la normalidad.

Los controles y las contramedidas no son un único conjunto homogéneo. Para dar como resultado una “buena” seguridad, las diversas amenazas deben ser combatidas por **capas de controles** dirigidos a diferentes aspectos del uso y management de los IS.

En el caso de los IS la naturaleza precisa de las instancias de cada capa de control dependerá de:

- La plataforma de HW: ejerce influencia en el tipo y la cantidad de controles disponibles
- El grado de distribución: influye en el énfasis de los controles
- La integración de la infraestructura: influye en la naturaleza de la amenaza.

Cualquier cambio en esto significa que las consecuencias de seguridad se extienden por todas las capas de control. Aun dentro de cada capa existen diferentes intenciones o **etapas de control**:

Estas tres etapas se aplican a la mayoría de las capas de control. Por ejemplo, el software de autorización puede tratar de prevenir el uso no autorizado, pero también registra los ingresos fallidos a fin de detectar los ataques y luego utiliza la encriptación de la segunda etapa para minimizar el daño causado por la entrada ilegal al sistema.

Primera línea de defensa	Prevención	Prevenir amenazas, evitar la ocurrencia de las amenazas; por ej., “prohibir que se fume en el centro de datos”
Segunda línea de defensa	Detección	Detectar fallas de seguridad a pesar de la primera línea de defensa, por ej., un detector de humo “si falla la primera línea es decir que ocurre el ataque debo detectarlo’
Tercera línea de defensa	Recuperación	Recuperarse de una falla de seguridad con pérdidas mínimas; por ej., backups de datos off- site. “recuperarte al estado anterior a la amenaza”.

Las herramientas de seguridad son una de las contramedidas a implementar. También tengo políticas de seguridad, buenas prácticas de seguridad.

El **principal objetivo** cuando se seleccionan controles y contra medidas y, por lo tanto, cuando se define la política de seguridad, es **crear una situación equilibrada entre los costos de riesgo y los costos de control**.

Las contramedidas seleccionadas pueden ser **lógicas o físicas**. Los **controles lógicos** son las medidas adoptadas para asegurarse de que el desarrollo, la integridad de los datos y las operaciones continúen sin tropiezos. Una de las medidas de control lógico más común, y a menudo, inadecuada, es la identificación del usuario y los sistemas de contraseñas para restringir el acceso a los sistemas. Las **medidas físicas** de seguridad generan más

costos, son menos efectivas y más propensas a producir resentimiento, y, por lo tanto, su uso debe ser cuidadosamente evaluado. Los controles físicos de seguridad pueden incluir el uso de personal de seguridad, sistemas de vigilancia, cerraduras, tarjetas con clave y otros métodos de acceso. Estas medidas filtran el acceso físico a la utilización de los elementos de IS.

Ejemplos de controles:

- Estándares de operatividad
- División de responsabilidades
- Medidas de seguridad de la red
- Contraseñas
- Encriptación de datos
- Antivirus
- Detección y prevención de incendios

Recuperación ante el desastre

Este elemento **asume que la prevención total del riesgo es poco práctica o imposible y** que, por lo tanto, la empresa debe definir planes que permite que la empresa sobreviva a algún tipo de desastre y de los procesos que permitan recuperación. Esto se denomina **planificación de contingencias, e incluye planes para métodos de trabajo que permitan que la empresa sobreviva al desastre**, y para procesos a largo plazo a fin de que la organización se recupere. La primera etapa consiste en incrementar la seguridad, minimizar los daños y facilitar el regreso al trabajo. En la segunda etapa se minimizan los efectos secundarios del desastre. Los términos relacionados con estas etapas son:

- **Tiempo de inhabilitación:** cantidad de tiempo antes de que los sistemas vuelvan a estar disponibles para las operaciones.
- **Respaldo:** mantener el funcionamiento de la empresa a través de los sistemas claves (críticos y vitales) hasta que se vuelva a la normalidad.
- **Reinstalación:** sistemas de actualización con todos los datos generados durante el tiempo de inactividad de la sede central.

Por supuesto que el management de riesgo busca prevenir en los casos en que esto es posible, pero también debe prepararse para los desastres. La recuperación ante desastres debe llevarse a cabo con rapidez a fin de estar listo para cualquier falla en la prevención del riesgo y, de hecho, una estrategia de reducción del riesgo reconoce que existe la probabilidad residual de una falla en la seguridad. **En algunos casos, cuando las consecuencias del riesgo son bajas, la prevención no es mejor que la cura y, entonces, la recuperación en si misma puede ser una estrategia adecuada para el manejo de riesgo.**

El primer paso de la planificación de contingencias consiste en clasificar los sistemas y aplicaciones de acuerdo con la necesidad de operaciones empresariales (**grado de tolerancia**). Esta clasificación permite establecer prioridades entre los elementos de los IS.

El plan de recuperación debe cubrir todos los aspectos del uso y del management de los SI. La clasificación propuesta por Lardent es:

	CRÍTICOS	VITALES	SENSIBLES	NO CRÍTICOS
Tolerancia a la interrupción	Muy baja (Costo de interrupción muy alto)	Moderada (Costo de interrupción ligeramente menor)	Flexible (costos tolerables)	Amplia (Costo escaso o costo adicional nulo)

Las organizaciones que disponen de un alto nivel de automatización están sometidas a mayores riesgos que aquellas escasamente mecanizadas y tendrán mayores dificultades para restaurar sus procedimientos, y además tendrán menor capacidad de procesar sus datos.

Como la planificación de contingencias es parte del management estratégico de los SI, no se la puede separar de otros aspectos de gerenciamiento del uso de los SI y debe ser considerada junto con otros temas de la selección y la implementación de estrategias.

Existen dos problemas importantes en la planificación ante desastres: la dificultad de mantenerse actualizado con los tiempos de desastre, y la dificultad de mantenerse actualizado con los cronogramas de prioridades.

Se deben tener backups y mantenerlos off-site para prevenir que los desastres posibles afecten a los mismos.

Las soluciones de respaldo (mantenimiento) pueden clasificarse en (disponibilidad de hardware alternativo en Lardent):

- **Instalaciones de emergencia:** en las que todo lo que posibilita el funcionamiento de IS ya está instalado; permiten una operatividad inmediata, siempre y cuando los backups de datos estén disponibles.
- **Instalaciones intermedias:** un centro de datos vacío pero equipado se encuentra disponible. Son menos costosas que el anterior pero su puesta en actividad es más lenta.
- **Instalaciones móviles:** la provisión se realiza desde vehículos o desde edificaciones prefabricadas semimóviles.

Todos los enfoques de desarrollo de los SI deben ofrecer puntos de recuperación.

Evaluación de riesgos (Lardent)

Los riesgos que interesan en este ámbito son los vinculados con la probabilidad de presentación de un desastre. **Un desastre es todo suceso sujeto a un cierto grado de incertidumbre en cuanto a su ocurrencia, pero que cuando ocurre tiene potencial como para interrumpir o afectar seriamente la operación normal de un negocio.**

Los riesgos deben ser clasificados a efectos de priorizar las acciones, en conformidad con la sensibilidad al tiempo (necesario para que se reanude el negocio luego de la ocurrencia de un desastre). La evaluación del riesgo debe considerar la tolerancia del sistema; esto es, la capacidad de enfrentar una interrupción de los sistemas. La tolerancia puede ser expresada como un valor monetario.

Formulación de un Plan de Contingencias (Lardent)

Definición de planes que permite que la empresa sobreviva a algún tipo de desastre y de los procesos que permitan recuperación. Se debe prever: tiempo de inhabilitación, respaldo o mantenimiento, reinstalación, tolerancia del sistema.

Se pueden diferenciar 3 tipos de situaciones de interrupción de las actividades:

1. **Catástrofe:** son interrupciones en la capacidad de procesamiento provocadas por la **destrucción de instalaciones y de los componentes físicos que las integran**. En estos casos se requiere acudir transitoriamente a otra instalación alternativa de configuración similar a la destruida. Simultáneamente debe equiparse una nueva instalación que, a muy corto plazo, tenga capacidad de procesamiento continuo del servicio de procesamiento de datos.

2. **Desastre:** Se trata de **interrupciones en la capacidad de procesamiento de información durante un periodo superior a un día**, pero con altas posibilidades de reanudar las mismas en la instalación original luego de superados los inconvenientes causantes de la interrupción. *Se deberá recurrir a una instalación de procesamiento alternativa* utilizando copias de software y de archivos de datos conservados fuera de la sede original.

3. **No desastres:** Se trate de **interrupciones breves que no duren más que un día**. Son provocadas por mal funcionamiento de algún dispositivo o por fallas en el software no detectadas anteriormente y que requieren inmediata corrección. Ejemplo: caída del campus

Todo sistema tiene un **lapso crítico de recuperación**. Este es el periodo o tiempo hasta donde puede extenderse una interrupción antes de que se presente el riesgo de incurrir en pérdidas. Es la naturaleza del negocio y de los sistemas lo que condiciona este lapso crítico.

La formulación del plan de contingencias es responsabilidad de la gerencia superior. **El plan de contingencias contendrá lo siguiente:**

- Determinación del orden de prioridades en materia de recuperación de aplicaciones, software de base y archivos de datos según el grado de tolerancia con respecto a la interrupción.
- Detalle del orden de procesamiento de tareas que lo requieran.
- Mecanismos de acoplamiento a los sistemas manuales durante interrupciones cortas.
- Tener en cuenta los equipos de todo el ambiente informático y no solo las unidades centrales. El personal debe ser entrenado. Sedes remotas
- Disponibilidad de hardware alternativo, las alternativas posibles son:
 - Centro duplicado de procesamiento de información de propiedad de la misma empresa (para aplicaciones críticas). Es eficaz pero costoso.
 - Centros de procesamiento ubicados en otra sede (por contratos con 3ros).

En función del tiempo de activación y costos se pueden clasificar en:

- Hot Sites: son instalaciones completas, configuradas de manera similar a la sede primaria y pueden activarse rápidamente.
- WarmSites: son instalaciones parcialmente configuradas en las que generalmente falta la unidad central de procesamiento. Dado que esta unidad es el dispositivo más costoso, esta alternativa es más económica.
- ColdSites: son lugares físicos que se encuentran en condiciones

de recibir el equipamiento necesario, pero no dispone de instalaciones específicas.

- Disponibilidad de la capacidad de telecomunicaciones para mantener activo los procesos críticos del negocio, los componentes y métodos más utilizados con este propósito son:
 - Rutas alternativas: se utiliza cuando se interrumpe la red normal.
 - Rutas diversificadas. Alternativas en distinto lugar físico.
- Disponibilidad de una sede alternativa para el almacenamiento de medios magnéticos (datos de backup) y documentación.

Metodologías de recuperación (Lardent)

Establece los pasos a seguir en las situaciones de emergencias.

- 1) Protección de la vida humana
- 2) Evaluación de daños y estimación de tiempo necesario para la recuperación.
- 3) Coordinación de las actividades de recuperación; recuperar datos vitales y críticos y reconstruir la base de datos; instalar y probar el software en una sede alternativa.
- 4) Restauración del software base y de aplicación en la sede alternativa.
- 5) Recuperación de la red de telecomunicaciones.
- 6) Preparación de datos y registro, supervisar los trabajos de obtención de datos fuente y de su carga y actualización de la base de datos.
- 7) Almacenamiento en sede alternativa, formular un cronograma y vigilar el cumplimiento de las actividades a desarrollar en sede alternativa para el almacenamiento de la información inicial y de la que se vaya generando durante el proceso de recuperación.
- 8) Administración de condiciones de seguridad.
- 9) Provisión de apoyo administrativo, tareas de control y balanceo de datos.
- 10) Gestión de aspectos legales derivados de la emergencia.

Técnica de auditoría y funciones del auditor en la continuidad de las operaciones (Lardent)

La revisión de la continuidad de operaciones exige del auditor de SI la ejecución de las tareas que se indican a continuación:

- Evaluación del plan de contingencias, verificación de su adecuación y actualización y de su capacidad para permitir reiniciar el procesamiento de información luego de una interrupción imprevista. Verificación de que el plan considere desastres de diverso grado. Verificación de que para cada aplicación se haya determinado su nivel de tolerancia.
- Examen del inventario detallado de los elementos almacenados en la sede alternativa.
- Evaluación del grado de capacitación del personal a efectos de poder enfrentar con éxito la aplicación del plan de contingencias.
- Verificación de que el plan contemple mecanismo de fusión de los datos obtenidos o procesados durante el periodo de emergencia, con los existentes antes del desastre.

- Evaluación de las condiciones de seguridad física de la instalación alternativa, en cuanto a controles de acceso.
- Examen del contrato de procesamiento alternativo con el proveedor de la instalación.
- Evaluación de los resultados de pruebas anteriores.
- Análisis de la cobertura de seguros.

Políticas de seguridad

Apunte Soria (1)

El termino se suele definir como el **conjunto de requisitos definidos por los responsables directos o indirectos de un sistema que indica en términos generales que está permitido y que no está permitido en el área de seguridad durante la operación general de dicho sistema**. (1)

Son medidas preventivas. Se usan en la primera medida de defensa. Una politica es: los empleados de atención al cliente no pueden cambiar los estados sino el que lo hace es el jefe de sección. (1)

Hay dos amplitudes de políticas:

- Políticas generales
- Políticas específicas: para cada activo, para cada situación, para cada perfil de usuario

Como son términos generales aplicables a situaciones y recursos diversos, suele ser necesario refinar los requisitos de la política para convertirlos en indicaciones precisas de que es lo que permitido y lo denegado en cierta parte de la operación del sistema, lo que se **denomina política de aplicación específica**. Serian como reglas. (1)

Una política puede ser

- **Prohibitiva:** *si todo lo que no está expresamente permitido está denegado.* Ejemplo: a tal área solo pueden entrar tales personas.
- **Permisiva,** *si todo lo que no está expresamente prohibido, está permitido.* Está prohibido solo lo que esta explicito que está prohibido. Ejemplo: no tomar mate, pero se puede comer

Las políticas prohibitivas son más efectivas en cuando a seguridad de un sistema se refiere. (1)

Cualquier política ha de contemplar seis elementos claves en la seguridad de un sistema informático:

- **Disponibilidad:** Es necesario garantizar que los recursos del sistema se encontrarán disponibles cuando se necesitan, especialmente la información crítica.
- **Utilidad:** Los recursos del sistema y la información manejada en el mismo ha de ser útil para alguna función.
- **Integridad:** La información del sistema ha de estar disponible tal y como se

almacenó por un agente autorizado.

- **Autenticidad:** El sistema ha de ser capaz de verificar la identidad de sus usuarios, y los usuarios la del sistema.
- **Confidencialidad:** La información sólo ha de estar disponible para agentes autorizados, especialmente su propietario.
- **Poseción:** Los propietarios de un sistema han de ser capaces de controlarlo en todo momento; perder este control en favor de un usuario malicioso compromete la seguridad del sistema hacia el resto de los usuarios. (1)

Definición de política

Política: Declaración general de principios que presenta la posición de la administración para un área de control definida. Las políticas se elaboran con el fin de que tengan aplicación a largo plazo y guíen el desarrollo de reglas y criterios más específicos que aborden situaciones concretas. Las políticas son desplegadas y soportadas por estándares, mejores prácticas, procedimientos y guías. Las políticas deben ser pocas (es decir, un número pequeño), deben ser apoyadas y aprobadas por las directivas de la universidad, y deben ofrecer direccionamientos a toda la organización o a un conjunto importante de dependencias. Por definición, las políticas son obligatorias y la incapacidad o imposibilidad para cumplir una política exige que se apruebe una excepción.

Estándar: Regla que especifica una acción o respuesta que se debe seguir a una situación dada. Los estándares son orientaciones obligatorias que buscan hacer cumplir las políticas. Los estándares sirven como especificaciones para la implementación de las políticas: son diseñados para promover la implementación de las políticas de alto nivel de la organización antes que crear nuevas políticas.

Mejor practica: Es una regla de seguridad específica a una plataforma que es aceptada a través de la industria al proporcionar el enfoque más efectivo a una implementación de seguridad concreta. Las mejores prácticas son establecidas para asegurar que las características de seguridad de sistemas utilizados con regularidad estén configurados y administrados de manera uniforme, garantizando un nivel consistente de seguridad a través de la organización.

Guía: Una guía es una declaración general utilizada para recomendar o sugerir un enfoque para implementar políticas, estándares y buenas prácticas. Las guías son, esencialmente, recomendaciones que deben considerarse al implementar la seguridad. Aunque no son obligatorias, serán seguidas a menos que existan argumentos documentados y aprobados para no hacerlo.

Procedimiento: Los procedimientos definen específicamente cómo las políticas, estándares, mejores prácticas y guías serán implementados en una situación dada. Los procedimientos son dependientes de la tecnología o de los procesos y se refieren a plataformas, aplicaciones o procesos específicos. Son utilizados para delinear los pasos que deben ser seguidos por una dependencia para implementar la seguridad relacionada a dicho proceso o sistema específico. Generalmente los procedimientos son desarrollados, implementados y supervisados por el dueño del proceso o del sistema. Los procedimientos seguirán las políticas de la organización, los estándares, las mejores

prácticas y las guías tan cerca como les sea posible, y a la vez se ajustarán a los requerimientos procedimentales o técnicos establecidos dentro de la dependencia donde ellos se aplican.

Ejemplo

En el nivel más alto, se puede elaborar una **política**, para toda la organización, que obligue a

“garantizar seguridad en el correo electrónico cuyo contenido sea información confidencial”.

Esta política podría ser soportada por varios **estándares**, incluyendo por ejemplo, que los mensajes de este tipo sean enviados utilizando algún sistema de criptografía aprobado por la universidad y que sean borrados de manera segura después de su envío. Una **mejor práctica**, en este ejemplo, podría estar relacionada sobre la manera de configurar el correo sobre un tipo específico de sistema (Windows o Linux) con el fin de garantizar el cumplimiento de la política y del estándar.

Los **procedimientos** podrían especificar requerimientos para que la política y los estándares que la soportan, sean aplicados en una dependencia específica, por ejemplo la Oficina de Control Interno.

Finalmente, las **guías** podrían incluir información sobre técnicas, configuraciones y secuencias de comandos recomendadas que deben seguir los usuarios para asegurar la información confidencial enviada y recibida a través del servicio de correo electrónico.

Ciclo de vida de una política

1. Fase de desarrollo:

- a. Creación: se planifica, investiga y redacta una política. Implica identificar la necesidad de la política, determinar el alcance de la misma y su aplicabilidad.
- b. Revisión: con la política documentada, se la remite a un grupo o individuo para su revisión independiente antes de la aprobación final.
- c. Aprobación: se debe obtener apoyo de la administración. La aprobación permite iniciar la implementación de la política.

2. Fase de implementación:

- a. Comunicación: consiste en difundir la política, concientizar a los miembros de la organización de la misma.
- b. Cumplimiento: se debe hacer seguimiento del cumplimiento de la misma.
- c. Excepciones: debido a problemas de gestión, no todas las políticas pueden cumplirse de la forma inicialmente planteada. Es por esto por lo que a veces existen excepciones que deben documentarse.

3. Fase de mantenimiento:

- a. Concientización: busca que las personas estén cumpliendo la política y entiendan su importancia en la estructura organizativa. Es un trabajo continuo.

- b. Monitoreo: realizar un seguimiento y reportar la efectividad de la política.
- c. Garantía de cumplimiento: identifica omisiones a la política para luego de un análisis de sus causas, intentar prevenir que sigan ocurriendo.
- d. Mantenimiento: la política es contingencial.

4. Fase de eliminación:

- a. Retiro: después de que la política haya cumplido con su finalidad y no es necesaria (por ejemplo, por grandes avances tecnológicos) debe ser retirada.

Clasificación y tipos de ataques contra sistemas de información

Se denomina **delito informático a toda acción culpable realizada por un ser humano, que cause perjuicio a otras personas sin que necesariamente se beneficie el autor o que, por el contrario, produzca un beneficio ilícito al autor, aunque no perjudique de forma directa o indirecta a la víctima, tipificado por la ley, que se realiza en un entorno informático y está sancionado con una pena.**

Un ataque no es más que la realización de una amenaza. Las cuatro categorías generales de amenazas o ataques son las siguientes:

- **Interrupción:** un recurso del sistema es destruido o se vuelve no disponible. Este es un ataque contra la **disponibilidad**. Ejemplos de este ataque son la destrucción de un elemento hardware, como un disco duro, cortar una línea de comunicación o deshabilitar el sistema de gestión de ficheros.
- **Intercepción:** una entidad no autorizada consigue acceso a un recurso. Este es un ataque contra la **confidencialidad**. La entidad no autorizada podría ser una persona, un programa o un ordenador. Ejemplos de este ataque son pinchar una línea para hacerse con datos que circulen por la red y la copia ilícita de ficheros o programas (intercepción de datos), o bien la lectura de las cabeceras de paquetes para desvelar la identidad de uno o más de los usuarios implicados en la comunicación observada ilegalmente (intercepción de identidad).
- **Modificación:** una entidad no autorizada no sólo consigue acceder a un recurso, sino que es capaz de manipularlo. Este es un ataque contra la **integridad**. Ejemplos de este ataque son el cambio de valores en un archivo de datos, alterar un programa para que funcione de forma diferente y modificar el contenido de mensajes que están siendo transferidos por la red.
- **Fabricación:** una entidad no autorizada inserta objetos falsificados en el sistema. Este es un ataque contra la **autenticidad**. Ejemplos de este ataque son la inserción de mensajes espurios en una red o añadir registros a un archivo. (1)

Estos ataques se pueden asimismo clasificar de forma útil en términos de ataques pasivos y ataques activos.

- **Ataques pasivos:** En los ataques pasivos **el atacante no altera la comunicación, sino que únicamente la escucha o monitoriza**, para obtener información que está siendo transmitida. Sus objetivos son la intercepción de datos y el análisis de tráfico. Los ataques pasivos son muy difíciles de detectar, ya que no provocan

ninguna alteración de los datos. Sin embargo, es posible evitar su éxito mediante el cifrado de la información y otros mecanismos.

- **Ataques activos:** Estos ataques implican algún tipo *de modificación del flujo de datos transmitido o la creación de un falso flujo de datos*, pudiendo subdividirse en cuatro categorías:
 - **Suplantación de identidad:** *el intruso se hace pasar por una entidad diferente.* Normalmente incluye alguna de las otras formas de ataque activo. Por ejemplo, secuencias de autenticación pueden ser capturadas y repetidas, permitiendo a una entidad no autorizada acceder a una serie de recursos privilegiados suplantando a la entidad que posee esos privilegios, como *al robar la contraseña de acceso a una cuenta.*
 - **Reactuación:** *uno o varios mensajes legítimos son capturados y repetidos para producir un efecto no deseado*, como por ejemplo ingresar dinero repetidas veces en una cuenta dada.
 - **Modificación de mensajes:** *una porción del mensaje legítimo es alterada*, o los mensajes son retardados o reordenados, para producir un efecto no autorizado. Por ejemplo, el mensaje "Ingresa un millón de pesos en la cuenta A" podría ser modificado para decir "Ingresa un millón de pesos en la cuenta B".
 - **Degradación fraudulenta del servicio:** *impide o inhibe el uso normal o la gestión de recursos informáticos y de comunicaciones.* Por ejemplo, el intruso podría suprimir todos los mensajes dirigidos a una determinada entidad o se podría interrumpir el servicio de una red inundándola con mensajes espurios. (1)

Auditoría

Se trata de una actividad que consiste en:

- **Contenido:** una opinión.
- **Condición:** profesional.
- **Justificación:** sustentada en determinados procedimientos
- **Objeto:** una determinada información obtenida en un cierto soporte. Es un informe. Esto se llama objeto de auditó (Dijo Soria en clase pero creo q no va acá esto).
- **Finalidad:** determinar si presenta adecuadamente la realidad o esta responde a las expectativas (objetivos de funcionamiento, de rendimiento) que le son atribuidas, es decir, su fiabilidad.

Por ejemplo: un auditor contable opina que el sistema contable auditado tiene un comportamiento aceptable de acuerdo con algo, o de un modo inaceptable de acuerdo con algo (normas, estándares, leyes, etc.).

Hay distintos tipos de auditoría (**naturaleza**): Financiera (evaluar la exactitud de los registros y estados contables), administrativa, de gestión de RRHH, (evaluar procedimientos de RRHH, procedimientos de remuneración variable, etc.), de calidad, operativa (evaluar la estructura de control interno en un área determinada, mide y evalúa la eficacia de otros controles) y de sistemas de información.

Una auditoría global involucra a la auditoría contable tanto como la auditoría operativa. La auditoría de sistemas es parte de la auditoría global.

La auditoría general involucra una auditoría externa e interna. Durante la planificación de la auditoría general debería establecerse una relación entre la actividad de los auditores externos y los internos. De esta forma, se evitan duplicaciones inútiles de esfuerzos y desperdicio de recursos. La coordinación de ambos grupos puede alcanzar una cobertura de auditoría más completa. **Si los controles y procedimientos son buenos, se hará hincapié en las pruebas de cumplimiento. Si por el contrario los controles son débiles o inexistentes, se harán más pruebas sustantivas.**

Auditoría de sistemas/informática (Lardent)

La auditoría de sistemas de información ha sido definida como la revisión sistemática organizada de los sistemas en funcionamiento para ver si ellos verifican las propiedades de:

- **Vigencia de los objetivos planteados como base del diseño original** (entendiendo por diseño el arreglo o coordinación de las partes o detalle del sistema).
- **Concordancia del sistema con los objetivos (efectividad).** Si está cumpliendo el objetivo
- **Permanencia del diseño por no haber sufrido alteraciones que lo degradaran operativamente.** Por ejemplo, que la lógica no este alterada.
- **Eficiencia del sistema (relación costo-beneficio).** Cuestión económica, mantener este sistema, así como está andando es eficiente, uso óptimo de los recursos,

¿minimización de los costos?

- **Seguridad del sistema**

Finalidad: evaluar si la operatividad de los sistemas se esté realizando en forma efectiva (fiable) y segura según normas establecidas (por ej., para banca alguna norma del banco central). La información se usa para la toma de decisiones y por ello la información debe ser certera.

La auditoría de sistemas debe asegurar con respecto a los sistemas, lo siguiente:

- La existencia de pistas de auditoría (trazabilidad, para que las operaciones puedan ser rastreadas).
- La existencia de controles adecuados respecto de la entrada de datos y al mantenimiento de la integridad de los mismos así, como también de las transacciones que se efectúan con ellos a través del segmento computarizado del sistema.
- El manejo adecuado de las excepciones y de los rechazos originados por los controles de entrada de datos, y el aseguramiento de su incorporación al sistema en los casos que corresponda.
- El aseguramiento de las políticas corporativas y el cumplimiento de reglamentos gubernamentales que hayan sido incorporados.
- La verificación de que los sistemas se comporten según fueron definidos.
- El aseguramiento de la adecuada interconexión de los sistemas.
- El control de que las modificaciones que se operen sobre los sistemas sean debidamente autorizadas por el nivel jerárquico que corresponda.
- La existencia de condiciones y procedimientos de seguridad que protejan los datos de la organización.

Objeto de auditor: recursos informáticos (servidor, pcs), función de SI (como unidad organizativa, gerencia de sistemas), aplicaciones, proyectos, planes de contingencia, los almacenamientos de datos, etc.

Aspectos a revisar por la auditoría de sistemas (Areas)

- Revisión de controles generales que afectan a la estructura de la organización, a las políticas y procedimientos y al ambiente de control de sistemas de información.
- Revisión de las operaciones de procesamiento de información en el ambiente informático.
- Revisión de seguridad en cuanto a la calidad del acceso lógico, físico y de los controles existentes en el ambiente informático.
- Revisión del software del sistema operativo.
- Revisión de la metodología de desarrollo de sistemas de información.
- Revisión de los controles de software de aplicación.
- Plan de contingencias: que exista y que sea coherente con los objetivos propuestos.

La Auditoría Informática tiene como objetivo evaluar periódicamente la eficacia, eficiencia e integridad de los sistemas de información, mediante la recolección y análisis de evidencias, y mediante la evaluación de los controles internos implementados, con el fin de verificar si estos salvaguardan los activos, aseguran la integridad de los datos,

garantizan el cumplimiento de los objetivos organizacionales y permiten un uso eficiente de los recursos.

La auditoría en informática es el proceso de recolección y evaluación de evidencias para determinar cuándo son salvaguardados los activos de los sistemas computarizados, de qué manera se mantiene la integridad de los datos y cómo se logran los objetivos de la organización eficazmente y se usan los recursos consumidos eficientemente. La auditoría en informática sigue los objetivos tradicionales de la auditoría: aquellos que son de la auditoría externa, de salvaguarda de los activos y la integridad de datos, y los objetivos gerenciales, aquellos propios de la auditoría interna que no sólo logran los objetivos señalados sino también los de eficiencia y eficacia.

Control interno informático (Piattini)

Como unidad organizativa: *Es el departamento, dirección, etc. que se crea para controlar diariamente que todas las actividades de los SI/TI sean realizadas cumpliendo los procedimientos, estándares y normas fijados por la dirección de la organización y/o la dirección informática, así como con los requerimientos legales (Piattini).*

Misión (finalidad): asegurarse que las medidas implementadas por cada responsable sean correctas y válidas. Es decir, se están cumpliendo.

Objetivos (como unidad organizativa):

- Colaborar con las auditorías informáticas tanto internas como externas. El área le provee el principal insumo
- Controlar que todas las actividades se efectúan de acuerdo con los procedimientos y normas fijados.
- Asesorar sobre el conocimiento y aplicación de las normas, así como asesorar y transmitir.
- Intervenir en la definición, implementación y ejecución de mecanismos y controles para comprobar el logro de los niveles de servicios adecuados (no es solo responsabilidad del CII (interno))
- Realizar sobre los diferentes SI y entornos informáticos en el control de actividades operativas como:
 - Cumplimiento de procedimientos, normas y controles (Cambios de versiones de SW).
 - Controles sobre la producción diaria.
 - Controles de calidad y eficiencia en el desarrollo y mantenimiento de SW.
 - Controles sobre redes y SW de base.
 - Controles sobre la seguridad informática.
 - Controles sobre las licencias y relaciones contractuales de los esquemas de outsourcing.

Los controles han de ser al menos completos, simples, fiables, revisables, adecuados y rentables. Respecto a esto último, habrá que analizar el coste-riesgo de su implantación.

Para asegurar la integridad, disponibilidad y eficacia de los sistemas se requieren complejos mecanismos de control, la mayoría de los cuales son automáticos.

Por ejemplo, tener un control de que los operarios de agunsa no se pasan las contraseñas, un mecanismo de control de que se dejan los dispositivos en un lugar previsto.

Similitudes y diferencias entre control interno y auditor informático interno (Piattini)

	Control interno informático	Auditor informático
Similitudes	Personal especializado en Tecnología de la Información Verificación del cumplimiento de controles internos, normativa y procedimientos establecidos por la Dirección de Informática y la Dirección General para los sistemas de información	
Diferencias	Análisis de los controles en el día a día (es continuo) Informa a la dirección del Departamento de informática Solo personal interno El alcance de sus funciones es únicamente sobre el Departamento de Informática	Análisis de un momento informático determinado Informa a la Dirección General de la organización Personal interno y/o externo Tiene cobertura sobre todos los componentes de los sistemas de información de la organización

Concepto de control interno: Se puede definir el control interno como *cualquier actividad o acción realizada manual o automáticamente para prevenir, corregir errores o irregularidades que puedan afectar al funcionamiento de un sistema para cumplir sus objetivos*. Se asemejan a las líneas de defensa.

Categorías de controles (Lardent)

1. **Preventivo:** son aquellos diseñados para evitar que se produzca un error, omisión, o actos maliciosos. Ejemplo: control de acceso lógico que permite solamente a personas autorizadas y desde lugares autorizados acceder a archivos de información sensible.

2. **Correctivo:** Corrige errores, omisiones, o actos maliciosos. Ejemplo: campo de fecha que corrige el formato ingresado o la recuperación de un archivo dañado a partir de las copias de seguridad. Buscar restablecer el funcionamiento de los sistemas si ocurrió algún daño

3. **De Detección:** detectan que se ha producido un error, omisión o acto malicioso, e informan de su aparición. Aparece cuando fallan los preventivos. Ejemplo: software de seguridad de acceso a través del cual quedan registradas intenciones de violación de acceso no autorizado.

Implantación de un Sistema de CII (Piattini)

Los controles pueden implantarse a varios niveles diferentes, por ello es importante conocer bien la configuración del sistema (el entorno). Para llegar a conocer la configuración del sistema es necesario documentar los detalles de red, así como los distintos niveles de control y elementos relacionados:

- Entorno de red
- Configuración del ordenador base
- Entorno de aplicaciones
- Productos y herramientas -> decidir que herramienta es una medida de control interno
- Seguridad del ordenador base

Para la implantación de un sistema de controles internos informáticos habrá luego de conocer la configuración del ambiente informático y luego definir:

- **Gestión de sistemas de información:** políticas, pautas y normas técnicas que sirvan de base para el diseño y la implantación de los sistemas de información y de los controles correspondientes.
- **Administración de sistemas:** controles sobre la actividad de los centros de datos y otras funciones de apoyo al sistema, incluyendo la administración de las redes.
- **Seguridad:** incluye las tres clases de controles fundamentales implantados en el software del sistema, integridad del sistema, confidencialidad (control de acceso) y disponibilidad.
- **Gestión del cambio:** separación de las pruebas y la producción a nivel de software y controles de procedimientos para la migración de programas software aprobados y probados. Hay garantías de que el diseño original del sistema se mantiene y los cambios no lo afectan en su esencia. La medida de control interno es como voy autorizando los cambios

La implantación de una política y cultura sobre la seguridad requiere que sea realizada por fases y esté respaldada por la Dirección. Cada función juega un papel importante en las distintas etapas:

- **Dirección de Sistemas de Información (SI):** Han de definir la política y/o directrices para los sistemas de información en base a las exigencias del negocio, que podrán ser internas o externas.
- **Dirección de Informática:** Ha de definir las normas de funcionamiento del entorno informático y de cada una de las funciones de Informática mediante la creación y publicación de procedimientos, estándares, metodología y normas aplicables a todas las áreas de Informática.
- **Control Interno Informático:** Define los controles periódicos a realizar en cada una de las funciones informáticas.
- **Auditor interno/externo informático:** ha de revisar los diferentes controles internos definidos en cada una de las funciones informáticas y el cumplimiento de normativa interna y externa.

La creación de un sistema de control informático es una responsabilidad de la Gerencia y un punto destacable de la política en el entorno informático.



Auditoría informática vs Control Interno Informático (Piattini)

La auditoría informática:

- Tiene la función de vigilancia y evaluación mediante dictámenes, y todas sus metodologías van encaminadas a esta función.
- Tiene sus propios objetivos distintos a los auditores de cuentas, aunque necesarios para que estos puedan utilizar la información de sus sistemas para sus evaluaciones financieras y operativas. Evalúan eficiencia, costo y seguridad en su amplia visión, esto es todos los riesgos informativos, ya sean los clásicos (confidencialidad, integridad y disponibilidad), o los costos y los jurídicos, dado que ya no hay una clara separación en la mayoría de los casos.
- Operan según el plan auditor.
- Utilizan metodologías de evaluación del tipo cualitativo con la característica de las pruebas de auditorías.
- Establecen planes quinquenales como ciclos completos.
- Sistemas de evaluación de repetición de la auditoría por nivel de exposición del área auditada y el resultado de la última auditoría de esta área.
- La función de soporte informático de todos los auditores (opcionalmente), aunque dejando claro que no se debe pensar con esto que la auditoría informática consiste en esto solamente.

Control Interno Informático

- Tiene funciones propias (administración de la seguridad lógica, etc.),
- Funciones de control dual con otros departamentos.
- Función normativa y del cumplimiento del marco jurídico.
- Operan según procedimientos de control en los que se ven involucrados y que luego se desarrollarán
- Al igual que en la auditoría y de forma opcional pueden ser el soporte informático de control interno no informático.

Etapas de la auditoría

Las etapas genéricas de la ISACA son:

- Planeación
- Trabajo de campo y documentación
- Reporte y seguimiento.

En la materia no se ve una metodología específica de auditoría, pero es importante tener en cuenta:

1. Identificar el **alcance** (*que voy a auditar y que no, describo los objetos de audito*) y los **objetivos** (*¿para qué hago la auditoría, hay degradaciones? ¿O evaluación pq hace poco fue implementado?*) de la auditoría informática es decir del objeto a estudiar.
2. Realizar el **estudio inicial** del entorno a auditar. (acá debería identificar los controles claves). Se hace para reducir riesgo inherente, identificar fuentes, etc.
3. Ejecución del **programa de revisión**. (Acá entra la metodología específica).
4. Cierre de la **revisión**. Junto todos los informes y miro los hallazgos.
5. Realizar **informe final**.
6. **Seguimiento** (las recomendaciones y ver si las medidas fueron adoptadas y la efectividad que tuvieron).

Para establecer el área o aplicación a auditar se deben establecer criterios y prioridades que identifiquen el orden en que se auditarán las diversas áreas. Esto está muy influenciado por el impacto en el negocio de las áreas auditadas, el nivel de activos controlados por el sistema, la dimensión de la aplicación, el impacto sobre la toma de decisiones, etc.

Programa de revisión

El **programa de auditoría** es un conjunto de instrucciones que guía a los auxiliares involucrados en la auditoría y como medio para el control y registro de la ejecución apropiada del trabajo. Dado que los programas de auditoría se preparan anticipadamente en la etapa de planeación, estos pueden ser modificados en la medida en que se ejecute el trabajo, teniendo en cuenta los hechos concretos que se vayan observando.

1. Deriva del plan de auditoría general.
 2. Se elabora un programa por cada área de auditoría, o sea, por cada sección a auditar.
 3. Detalla:
 - a. La naturaleza, oportunidad y **alcance** de los procedimientos de auditoría en según el plan general de AI.
 - b. Una descripción de los **objetivos** de auditoría.
 - c. Las fuentes de evidencias.
 - d. El equipo de auditoría.
 - e. Programa de trabajo específico: Para cada objetivo: pruebas, actividades, hitos de revisión, presentación de informes parciales, tiempo estimado, tiempo real, la referencia de papel de trabajo donde quedó plasmada la ejecución del programa, la rúbrica de quien realizó cada paso y la fecha del mismo.
- Condiciones o situaciones que requieran toma de decisiones.

Pasos para la ejecución de una auditoría de sistemas de información (Lardent)

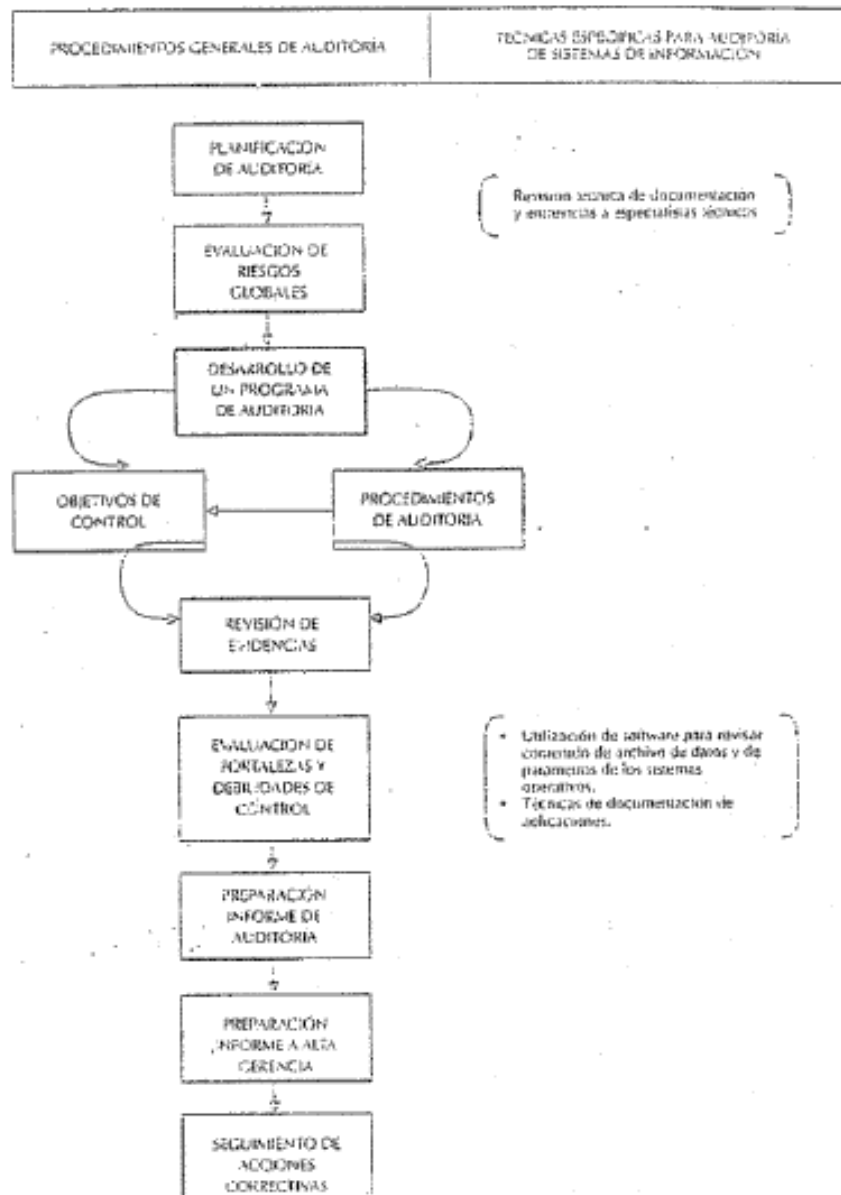


Figura 20-5. Desarrollo de una Auditoría de Sistemas de Información.

Planificación de una auditoría

Entre los aspectos que debe considerar el auditor de sistemas de información en el momento de la planificación se encuentran los siguientes:

- **Conocimiento del negocio y su ambiente:** conocer el negocio significa saber qué es lo que se va a revisar y sobre que se va a opinar. El auditor debe conocer también el ambiente normativo en el que opera el negocio. La información relativa al conocimiento

del negocio, relacionada con el procesamiento de datos, se obtiene recorriendo las instalaciones de la organización, manteniendo entrevistas con los gerentes usuarios de la información, con el personal del departamento de sistemas, además de la lectura de planes estratégicos a largo plazo y de todo el material que reúna antecedentes de la organización.

- **Evidencia de auditoría y auditabilidad:** la actividad de Auditoría de SI debe contar con la existencia de fuentes verificables de evidencia de auditoría, que son necesarias para probar los controles o para realizar procedimientos de pruebas de sustanciación.

La planificación de la auditoría incluye:

- Determinar el área o aplicación a auditar: identificar el área que será auditada.
- Definir el objetivo: determinar el objetivo o propósito de la auditoría
- Establecer el alcance: identificar los sistemas, aplicaciones o módulos que se revisaran para acotar la revisión, así como la duración de la auditoría. El auditor no puede auditar todos los sistemas al mismo tiempo, se deben establecer criterios que faciliten ese ordenamiento.
- Planear los recursos: Determinar los recursos necesarios para llevar a cabo la auditoría

Evaluación de riesgos globales

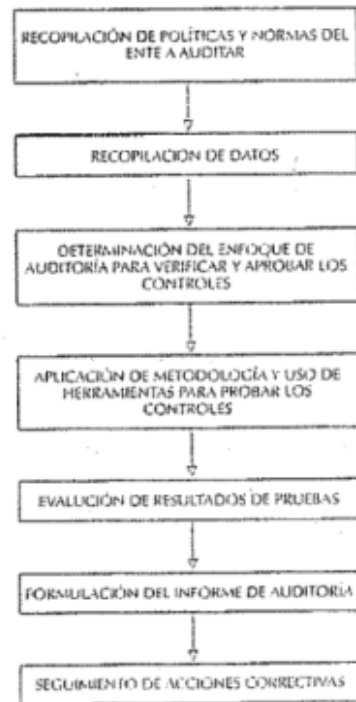
En la auditoría, el **riesgo** se refiere a la posibilidad de que la información pueda contener errores materiales (significativos en los estados contables), o bien la posibilidad de que el auditor no detecte errores ocurridos. Los riesgos pueden ser:

- **Riesgo Inherente:** es aquel riesgo que se produzca un error material debido a la *propia naturaleza de la actividad*. Esta fuera de poder ser controlado por el auditor como para poder eliminarlo. Por ejemplo, yo puedo hacer una auditoría de la función informática, pero si la auditoría se dedica al desarrollo yo no soy el indicado, no domino la naturaleza de lo que estoy auditando. Para reducirlo se hace el análisis inicial de la organización
- **Riesgo de control:** es el riesgo de que un error material no pueda ser evitado o detectado en forma oportuna por *deficiencias en el sistema de control interno*. Esta fuera de poder ser controlado por el auditor como para poder eliminarlo, pero sus recomendaciones deben contribuir a reducirlo.
- **Riesgo de detección:** es el riesgo que se corre cuando el auditor realiza *pruebas exitosas a partir de un procedimiento de prueba inadecuado*. Por lo tanto, se puede llegar a la conclusión de que no existen errores cuando en realidad, los hay. Es del ámbito y tarea exclusiva del auditor.

Estos riesgos también tienen una implicancia material, que significa plata.

Desarrollo del programa de auditoría

Una vez finalizada la planificación, previa a la ejecución de la auditoría, quedará definido el tema y área a auditar, el objetivo de la auditoría, su alcance (uno o varios sistemas o un espacio de tiempo determinado), las habilidades técnicas y recursos necesarios y la identificación de las fuentes de información para ejecución de pruebas y revisiones. La figura indica los siguientes pasos a desarrollar:



La importancia de los procedimientos (Soria Ojeda)

Dentro de la planeación hay que entender la importancia de los procedimientos para garantizar que todo lo que sigo y lo que fundamenta la opinión es lo correcto.

Son el fundamento y a la vez la justificación de la opinión profesional ya que:

- **Son los que proporcionan una seguridad razonable de lo que se afirma** (obtener evidencias y conclusiones). Si hay una receta razonablemente me va a salir si le cambio las cosas ya no
- **Determinan la trascendencia (impacto) de la auditoría.**

En cuanto a la ejecución de la auditoría, los procedimientos deben establecerse para:

- Planificar y supervisar la auditoría
- Estudiar y evaluar el control interno
- Obtener evidencia suficiente y adecuada

Evidencia en la auditoría (Lardent)

El concepto de *evidencia* es definido como el conjunto de información (todo dato, documento, registro o testimonio) que ha reunido el auditor, y que dispone para determinar si el ente o los datos auditados han cumplido con los criterios u objetivos de auditoría.

La evidencia debe reunir condiciones de calidad:

- La evidencia **relevante**, que tiene una relación lógica con los objetivos de la auditoría.
- La evidencia **fiable**, que es válida y objetiva, aunque con nivel de confianza.
- La evidencia **suficiente**, que es de tipo cuantitativo para soportar la opinión profesional del auditor.
- La evidencia **adecuada**, que es de tiempo cualitativo para afectar las conclusiones del auditor.

Se debe considerar la confiabilidad de la evidencia en que se apoya el auditor:

- **Evidencia de fuentes externas:** aquella obtenida por fuera de la organización. Es más confiable ya que en principio, es objetiva.
- **Objetividad:** la evidencia objetiva es más preferible a la que tiene que emitirse un juicio de valor.
- **Calidad de la fuente de evidencia:** la calificación de la confiabilidad de la evidencia depende de las características de quien provee la información.

La evidencia se recopila durante el proceso de auditoría y es el fundamento sobre el cual se formulan las conclusiones. **Las pruebas son el método o proceso mediante el cual se obtiene la evidencia. Son las acciones realizadas para recopilar información que servirá de base para las conclusiones del auditor.** En principio, las pruebas son de cumplimiento o sustantivas.

Tipos de pruebas (Lardent)

Existen dos categorías de pruebas diferenciadas por la auditoría: las pruebas de cumplimiento y las pruebas sustantivas.

1. Una prueba de cumplimiento tiene por objeto *determinar si los controles que se hacen se ajustan a las políticas y procedimientos de la organización, y si se aplican conforme a la descripción de la documentación de los programas de computación.* Su insumo es la documentación. Ejemplo: verificar que el programa en uso sea la misma versión que el que las versiones fuente y objeto almacenados en la biblioteca. Se clasifican en:

a. Pruebas de detalles: requieren la revisión de documentos. Es más pasivo.

b. Pruebas de observación e indagación: implica la tomar acciones para detectar errores. Son más activas. Por ejemplo: indagar al personal, aplicar programas de revisión de archivos, etc.

2. Las pruebas sustantivas intentan *verificar la adecuación de los controles existentes para proteger a la organización de las actividades fraudulentas. Le importa cómo se procesa la información.* Va a indagar, haciendo por ejemplo procesamiento en paralelo para ver que los controles que están implementados (manuales y automatizados) son resistentes a intentos de alterar la información. *Acá pruebo los sistemas,* apunta al tratamiento de la información, *garantizan que los sistemas hacen lo que tienen que hacer,* acá se usan herramientas informáticas.

Objetos (secciones de la auditoría de sistemas) (Lardent)

Áreas de la auditoría de SI:

1. Evaluación de la función informática (organización y administración del ambiente informático).
2. Evaluación de los sistemas y procedimientos.
 - a) Auditoría del desarrollo de sistemas.
 - b) Auditoría de sistemas instalados.
3. Evaluación del proceso de datos, de los sistemas y equipos.
4. Evaluación de la seguridad.
5. Evaluación de los aspectos legales de los sistemas y de la información.

Deontología (reglas éticas) del auditor (Piattini 7)

Es el conjunto de principios y reglas éticas que regulan y guían a una actividad profesional.

Estas normas determinan los deberes mínimamente exigibles a los profesionales en el desempeño de su actividad.

Principio de Beneficio del auditado: no ir con un prejuicio.

Principio de independencia: asegura que el auditor va a ser objetivo. No puede auditar nada que lo vincule con lo que está auditando. Independencia de criterio. Para la interna tiene que estar garantizado con la estructura organizativa (deberá depender del gerente), no debe estar involucrado en el área de desarrollo.

Auditoría interna

Según la relación del auditor con la empresa una auditoría puede ser interna o externa.

Es el examen crítico, sistemático y detallado de un sistema de información de una unidad económica, realizado por un profesional con vínculos laborales con la misma, utilizando técnicas determinadas y con el objeto de emitir informes y formular sugerencias para el mejoramiento de la misma. Estos informes son de **circulación interna**.

La auditoría interna es un servicio que reporta al más alto nivel de la dirección de la organización y tiene características de función asesora de control, por tanto, no puede ni debe tener autoridad de línea sobre ningún funcionario de la empresa, a excepción de los que forman parte de la planta de la oficina de auditoría interna, ni debe de algún modo involucrarse o comprometerse con las operaciones de los sistemas de la empresa.

La tarea de la auditoría interna exige una absoluta **independencia de criterio por parte del auditor**. Esta independencia se consigue por medio de la **estructura organizacional y de la objetividad**. La organización debe estar estructurada de tal manera que la auditoría interna tenga suficiente autoridad como para tomar acción sobre el personal de línea, frente a recomendaciones o hallazgos del auditor. La objetividad se manifiesta mediante la imposibilidad de que el auditor se involucre en el desarrollo e instalación de procedimientos que deberán luego ser evaluados por el mismo implementador. No obstante, el auditor debe participar en la determinación de aquellos **puntos de control** que deben estar incorporados en todo sistema de información.

Objetivo: descubrir *deficiencias o irregularidades* en algunas de las partes de la empresa examinada, y apuntar hacia sus posibles soluciones actuando como auxiliar de la dirección para lograr una administración optima.

No la puede hacer un personal “jefe de línea”. Busca ayudar a la gerencia a ejecutar sus funciones con efectividad.

Auditoría externa

Es el examen crítico, sistemático y detallado de un sistema de información de una unidad económica, realizado por un profesional, sin vínculos laborales con la misma, utilizando técnicas determinadas y con el objeto de emitir una opinión independiente sobre la forma como opera el sistema, el control interno del mismo y formular sugerencias para su mejoramiento.

Una auditoría externa se lleva a cabo cuando se tiene la intención de publicar el producto del SI examinado con el fin de acompañar al mismo una opinión independiente que le de autenticidad y permita a los usuarios de dicha información tomar decisiones confiando en las declaraciones del auditor.

Se reporta a organismo oficiales públicos y/o determinadas empresas. *Tiene implicancias legales.* La periodicidad es puntual. *Está habilitada legalmente para dar fe pública.* Es imprescindible para obtener certificaciones.

Objetivo: averiguar la razonabilidad, integridad y autenticidad de los estados, expedientes y documentos y toda aquella información producida por los sistemas de la organización.

Comparativa		
	Auditoría externa	Auditoría interna
Sujeto	Profesional independiente	Empleado
Objetivo	Examen de los estados financieros, operacionales	Control de operaciones y gestión
Origen del encargo	Obligatoria, legal o estatutaria	Voluntaria
Alcance	Estado de los sistemas de información en su conjunto	Restringida departamento informática
Uso del informe	Empresa y público en general	Restringida a empresa o institución pública
Grado de independencia	Total	Limitada
Responsabilidad	Profesional, civil y penal	Profesional
Continuidad del trabajo	Periódico (habitualmente anual)	Continuo
Intensidad del trabajo	Menor	Mayor

Informes de auditoría (Lardent)

El trabajo de auditoría concluye con un informe, su posterior seguimiento, y también con los cursos de acción que debieran surgir debido a las recomendaciones contenidas en el informe.

El informe refleja las conclusiones a las cuales arribó el auditor luego de desarrollar su programa y recopilar las evidencias de auditoría. El informe de Auditoría Informática es la comunicación del Auditor Informático al cliente, formal, tanto del alcance de la auditoría; (objetivos, período de cobertura, naturaleza y extensión del trabajo realizado) como de resultados y conclusiones.

Es momento adecuado de separar lo significativo de lo no significativo debidamente evaluados por su importancia y vinculación con el factor riesgo, tarea eminentemente de carácter profesional y ético, según el entender del Auditor Informático.

Aunque no existe un formato vinculante, si existen esquemas recomendados con los requisitos mínimos aconsejables respecto a estructura y contenido.

También es cuestión previa decidir si el informe es largo o, por el contrario, corto, por supuesto con otros informes sobre aspectos, como el informe de debilidades del control interno, incluso de hechos o aspectos.

Estructura básica de un informe de auditoría (Lardent)

- 1) Introducción:** debe incluir los objetivos de la auditoría, el área o funciones abarcadas, el periodo que cubrió la revisión y el alcance o extensión de los procedimientos de auditoría utilizados.
- 2) Descripción de los hallazgos y formulación de recomendaciones:** se incluirán las fuentes de evidencia.
- 3) Detalles de las acciones correctivas a desarrollar**
- 4) Opinión del autor sobre la situación encontrada:** se refiere a la adecuación de los controles, grado de cumplimiento de los mismos y conclusión sobre los procedimientos que fueron sujetos a revisión. La opinión del auditor debe quedar respaldada en el informe a través de las evidencias recopiladas durante la ejecución de la revisión.

5) **Anexos:** tiene el propósito de mencionar información muy detallada a la que el lector podrá recurrir o no de acuerdo con sus intereses o predisposición. Se trata de detalles que podrán ser importantes pero cuya inclusión en el texto principal puede provocar en el lector la desviación de su atención del tema básico hacia detalles secundarios. Cuando el informe incluye anexos en el texto del mismo deberá hacerse referencia a la información ampliatoria o aclaratoria.

Según Soria primero debería ir la opinión y después los hallazgos

Tipos de informes (Lar dent)

- **Informe sin salvedades:** significa que la revisión de auditoría *no encontró problemas materiales o controles débiles no compensados*. Se expresa que “los estados contables están de acuerdo con principios de contabilidad generalmente aceptados”.
- **Informe con salvedades:** el auditor manifiesta que, si bien los estados contables de la empresa cumplen con las normas de contabilidad generalmente aceptadas, *se presenta alguna condición de excepción que debe ser expresamente expuesta*.
- **Informe con opinión adversa:** los estados contables auditados *no cumplen con las normas* contables generalmente aceptadas, o bien, no se compensan los *controles débiles encontrados*.
- **Informe sin opinión:** se emite en los casos en que el alcance de la auditoría es limitado o bien cuando la situación financiera de la organización auditada permite pensar en una posible disolución.

Auditoría de la Función Informática (Auditoría de Organización y Administración del Ambiente Informático)

La evaluación de la función informática consiste en analizar la organización y administración del ambiente informático de la organización, asegurándose de que los recursos de TI estén bien gestionados, alineados con los objetivos de la empresa, y operando de manera eficiente y efectiva. Área de sistemas

Las funciones específicas del auditor de sistemas de información deben incluir:

- Tener una comprensión precisa del ambiente informático de la organización por medio de la identificación de las áreas funcionales que procesan información, también oír sus asignaciones y responsabilidades.
- En función de esa comprensión, evaluar la estructura organizacional del ambiente informático y verificar su adecuación a las políticas institucionales.
- Evaluar el ambiente de control de la organización para verificar si se cumplen los objetivos de control que otorgan confiabilidad al procesamiento de información.
- Efectuar pruebas de controles y evaluar sus resultados.
- Detectar las debilidades que puedan existir desde el punto de vista de gestión y del impacto que producen sobre los procedimientos de auditoría. Las debilidades serán una indicación de la necesidad de efectuar más esfuerzos de auditoría en ciertas áreas.

La auditoría de organización propone los siguientes **propósitos**:

- Verificar que la estructura organizativa asegure una adecuada separación de funciones para cumplir con principios de control interno.
- Asegurar la protección de archivos para mantener la continuidad de las operaciones bajo condiciones normales de procesamiento.

- Verificar la presencia de un buen diseño de control interno a causa de acotar las deficiencias y riesgos de procesamiento.
- Verificar que se mantenga un control eficaz en los niveles de autorización de datos y de procedimientos.
- Examinar si existen estándares de actuación y evaluar su adecuación y vigencia.
- Analizar el nivel de formación del personal y evaluar si por medio del mismo se alcanzan los estándares diseñados.

Elementos a auditar:

Evalúa las políticas, la administración, estructura organizativa y aplicación de controles en un ambiente informático, esto incluye:

- Plan de organización: este tiene la división de responsabilidades
- Segregación de las funciones (en el dpto. de procesamiento de la información)
- Ambiente Informático

Auditoria del Desarrollo de Sistemas

Se audita para mejorar. (Vero)

Lardent: El objetivo de este tipo de auditoria consiste en identificar, analizar y evaluar los requerimientos del usuario, así como también los riesgos, las exposiciones a riesgos y los controles que deben ser incorporados a los sistemas de aplicaciones durante las fases de desarrollo. **Verificar que los sistemas se desarrollen siguiendo las metodologías establecidas y que se cumplan con los requisitos del negocio.**

Lo importante es identificar los puntos de control.

Lardent propone la función del auditor como función asesora para ayudar a definir los puntos de control, el problema es después quien hace el control. La persona que después haga la auditoria debe ser alguien distinto al que ayudo a definir los puntos de control.

Se busca contribuir a la calidad y a la confiabilidad del sw. La auditoría se puede hacer en 4 niveles:

- Revisión del ciclo de vida: si en el área de desarrollo me dedico a desarrollar. Desarrollo del plan maestro. Evaluación de la factibilidad, que haya una para cada uno de los proyectos. Fases del desarrollo del proyecto (antes de hacerlo hay que saber el framework a utilizar).
- Auditoria de la documentación de sistemas: propone por etapa los documentos que se debe tener.
- Auditoria de adquisición del sw: analizar solvencia del proveedor. Recupero del código fuente. Establecer mecanismo de recupero del código fuente (quien es el propietario). Documentación de respaldo. Nivel de satisfacción de otros clientes. Capacidad de actualizaciones.
- Auditoria de modificación de programas: autorización de cambios. Trazabilidad de los cambios. Documentación de programas y sistemas.

Funciones del Auditor (LARDENT)

- Determinar los objetivos y requerimientos básicos de los usuarios del sistema e identificar las áreas afectadas por el mismo.
- Determinar y clasificar los riesgos y exposiciones a riesgos del sistema.
- Procurar la identificación de controles necesarios con el propósito de minimizar los

riesgos y exposiciones a riesgos del sistema. Los puntos de control.

- Asesorar a los miembros integrantes del proyecto de desarrollo del sistema respecto de la incorporación de controles en el diseño y de módulos de auditoría, que permita, una vez implementado el mismo, las revisiones de rutina a través de las pistas de auditoría.
- Asegurar que se sigan los pasos definidos en la metodología de desarrollo aplicada.
- Verificar que se haya efectuado la evaluación de factibilidad y que la misma sea consistente y completa.

Piattini: La función auditora es la encargada de comprobar la existencia de procedimientos de control y de verificar su correcta definición y aplicación para determinar las deficiencias que existan al respecto y los **riesgos** asociados a estas carencias de control.

Propone usar la metodología ISACA para evaluar riesgos definiendo objetivos de control. El auditor evalúa el grado en el que se cumple o no esto y para ello hay pruebas asociadas a cada uno de estos criterios (técnicas de control). Para cada cosa a auditor n objetivos de control para cada objetivo n técnicas y para cada técnica una o varias pruebas.

- Auditoria de la organización: como administra las personas. Propone 8 objetivos de control.
- Auditoria de proyectos: se hace un plan distinto por cada proyecto dependiendo de riesgos, complejidad y recursos.

Comparación entre ambos autores:

Piattini si dice los pasos que hay que hacer, Lardent solo propuestas generales., por lo tanto, es más flexible, el auditor decide en que punto pone el foco.

Lardent se enfoca mas en el marco institucional y organizacional del desarrollo, con una mirada puesta en la productividad, los costos y los aspectos normativos.

Piattini propone un enfoque más estructurado y técnico, centrado en la auditoria detallada del ciclo de vida del desarrollo de sistemas, con herramientas y listas de verificación por cada etapa.

Elementos a auditar:

- Plan Maestro (Plan de SI/TI)
 - Verificar la concordancia del plan, así como de los sistemas que incluye.
- Estudio de factibilidad
- Documentación
- ERS
- Metodología utilizada
- Cada fase del desarrollo del proyecto
 - Definición y analisis de requerimientos
 - Diseño lógico del sistema
 - Diseño físico del sistema
 - Prueba del sistema
 - Implantación
 - Post Instalación(Mantenimiento).

No confundir auditoria con certificación de calidad, la certificación utiliza la auditoria, pero yo puedo hacer una auditoria para saber si estoy haciendo las cosas bien.

Auditoria de Sistemas de Aplicación Instalados

Los componentes de los sistemas de aplicación instalados comprenden funciones de captura e ingreso de datos, funciones de procesamiento de esos datos, funciones de almacenamiento y funciones de salida de información.

Es necesario activar controles sobre esas funciones. Los controles intentan asegurar que:

- En un sistema computarizado solamente se ingresen datos completos, exactos, válidos y autorizados (y por única vez).
- La actualización de esos datos se efectúe en los momentos en que realmente corresponda y bajo las mismas condiciones de seguridad arriba señaladas.
- El procesamiento se realice a tiempo y cumpliendo con el diseño aprobado del sistema según sus objetivos.
- Los datos se mantengan protegidos y actualizados.
- Las salidas (resultados del procesamiento) cumplan las expectativas formuladas en el momento de definición del proyecto.

Funciones del Auditor

- Obtener una comprensión profunda de cada aplicación a través del examen de la documentación y de la investigación, con el propósito de identificar los componentes significativos de la misma y el flujo de datos entre los mismos. De ese análisis surgirán las estrategias para el desarrollo de pruebas de auditoría.
- Evaluar los controles incorporados a las aplicaciones para identificar sus fortalezas y debilidades, para definir los objetivos de control.
- Probar los controles existentes para evaluar su funcionalidad, utilizando adecuados procedimientos de auditoría.
- Evaluar el ambiente de control para determinar si se han alcanzado los objetivos del mismo al analizar los resultados de las pruebas.
- Analizar la eficiencia y eficacia de las operaciones que componen la aplicación, comparándolas con estándares de programación y considerando a la tecnología y procedimientos utilizados.
- Verificar el grado de cumplimiento, a través de la aplicación, de los objetivos de la gerencia (formulados en el momento de definición del sistema).

Elementos a Auditar:

- Sistemas de entrada y captura de datos.
- Procesos y métodos de procesamiento de datos.
- Control de la salida

Auditoria de la Seguridad (GPT)

Concepto: esta auditoría tiene como objetivo verificar el funcionamiento correcto, eficaz y eficiente de los sistemas informáticos, prestando especial atención a aspectos como la seguridad física, lógica, de redes, y de los procesos de desarrollo y mantenimiento de los sistemas. Es una rama especializada de la auditoría informática que asegura que los sistemas cumplan con políticas, normas y estándares establecidos para proteger la información crítica de la organización.

Funciones del Auditor:

- Evaluar los controles de acceso para garantizar que solo los usuarios autorizados puedan acceder a sistemas y datos sensibles.

- Comprobar la protección contra ataques cibernéticos, como virus, malware, y phishing.
- Revisar las políticas de seguridad, protocolos de encriptación y sistemas de respaldo de datos.
- Verificar el cumplimiento de normativas de seguridad (por ejemplo, normas de privacidad de datos, ISO 27001).

Síntesis de los elementos a auditar:

- Controles de acceso a sistemas y datos.
- Protección contra amenazas externas e internas.
- Políticas de seguridad de la información.
- Plan de recuperación ante desastres y copias de seguridad.
- Cumplimiento con normativas de seguridad.

Técnicas de evaluación y auditoría

Al margen de la estrategia seleccionada para la revisión (con o sin computadora). El auditor de sistemas debe desarrollar actividades específicas tales como las que se indican a continuación.

- Verificación de la segregación de funciones
- Revisión de la documentación de sistemas
- Un plan de documentación
 - Definición del problema
 - Descripción del sistema (análisis y diseño lógico)
 - Descripción de los programas (diseño físico o ingeniero de software)
Configuración de registros, diccionarios de datos, esquemas de bases de datos, pantallas e informes
 - Instrucciones de operación
 - Descripción de controles
 - Registro de aceptación

ETAPAS DE AUDITORÍA DE ISACA

